

UNIVERSIDADE DO MINHO

ESCOLA DE ENGENHARIA



Gestão e Segurança de Redes - TP2

Mestrado em Engenharia Informática

pg54133

Paulo Oliveira

1 Introdução

Para o trabalho prático 2, foi-nos proposto pelos docentes a realização um trabalho de investigação sobre segurança, nomeadamente, a realização de um estudo sobre as principais ameaças de segurança que os serviços fundamentais da Internet, como o DNS podem sofrer. Estes serviços são pilares essenciais para a funcionalidade e a conectividade da rede. No entanto, são frequentemente alvos de ameaças de segurança que podem comprometer a integridade, a disponibilidade e a confidencialidade dos sistemas de informação. Este estudo examina as principais ameaças de segurança enfrentadas pelo DNS e DHCP, apresenta casos específicos de interrupções de serviço e ataques realizados a estes serviços e discute as melhores práticas e mecanismos de segurança atuais para fortalecer os mesmos.

2 Contextualização

Neste estudo, são tidos em consideração os serviços fundamentais da Internet:

- **DNS** - *Domain Name System* - sistema que traduz nomes de domínio legíveis por humanos (como por exemplo `www.youtube.com`) em endereços IP numéricos (como por exemplo `192.0.2.1`) que os computadores utilizam para identificar e se comunicar com outros dispositivos da rede, facilitando a navegação e a localização de recursos online.
- **DHCP** - *Dynamic Host Configuration Protocol* - protocolo de rede utilizado para atribuir automaticamente endereços IP e outras configurações de rede a dispositivos em uma rede, permitindo aos dispositivos se conectarem e comunicarem na rede sem a necessidade de configuração manual, simplificando a gestão e manutenção da rede.

2.1 Funcionamento dos serviços

2.1.1 DNS

Quando um utilizador insere um nome de domínio no navegador, a solicitação é enviada a um servidor DNS resolver, que verifica a sua cache por um registo correspondente. Se não encontrar, inicia consultas recursivas. O resolver primeiro pergunta a um servidor raiz pelo endereço IP do servidor de nomes para o domínio de nível superior (TLD). O servidor raiz responde com o endereço IP do servidor TLD apropriado. O resolver então consulta o servidor TLD para obter o endereço IP do servidor de nomes autoritativo para o domínio específico. O servidor TLD fornece o endereço IP do servidor autoritativo, e o resolver consulta este servidor para obter o endereço IP final do nome de domínio solicitado. O servidor autoritativo retorna o endereço IP, que é enviado pelo resolver ao navegador do utilizador. Com o endereço IP, o navegador estabelece uma conexão com o servidor web e carrega o site solicitado.

2.1.2 DHCP

Quando um dispositivo (cliente) se conecta à rede pela primeira vez, ele envia um pacote de descoberta (DHCP Discover) em broadcast para localizar um servidor DHCP disponível. Os servidores DHCP respondem com um pacote de oferta (DHCP Offer), contendo um endereço IP disponível e outros parâmetros de configuração, como máscara de sub-rede, gateway padrão e servidores DNS. O cliente então escolhe uma das ofertas recebidas e responde com um pacote de solicitação (DHCP Request), indicando que aceita a oferta de um servidor específico e deseja usar o endereço IP oferecido. O servidor DHCP selecionado confirma a atribuição do endereço IP enviando um pacote de confirmação (DHCP Acknowledgment) ao cliente, que pode incluir informações adicionais, como o lease (período de tempo durante o qual o endereço IP é atribuído). O cliente configura a sua interface de rede com o endereço IP e os parâmetros recebidos, começando a comunicar na rede. Antes do lease expirar, o cliente tenta renová-lo enviando um novo pacote de solicitação ao servidor DHCP. Se o lease não puder ser renovado, o cliente repetirá o processo de descoberta para obter um novo endereço IP.

2.2 Características dos serviços

2.2.1 DNS

- Distribuição Global - Este sistema é distribuído mundialmente, com milhares de servidores interconectados que asseguram tanto a disponibilidade quanto a redundância.
- Estrutura Hierárquica - O DNS é organizado em uma estrutura hierárquica, o que simplifica a organização e a resolução de nomes de domínio.
- Usabilidade - Facilita a navegação na Internet, permitindo que os usuários utilizem nomes simples em vez de endereços IP, tornando a pesquisa mais intuitiva e amigável.
- Acessibilidade - Proporciona aos usuários um acesso fácil a websites e serviços online.
- Escalabilidade - Suporta o contínuo crescimento da Internet, gerenciando bilhões de solicitações diariamente.
- Conectividade - Promove a comunicação entre dispositivos em redes locais e na Internet global.

2.2.2 DHCP

- Automatização - O DHCP simplifica a configuração de rede, eliminando erros humanos e poupando tempo.
- Escalabilidade - Adequado para redes de qualquer tamanho, desde pequenas redes locais até grandes sistemas corporativos.
- Flexibilidade - Além de distribuir endereços IP, também configura outros parâmetros como máscaras de sub-rede, gateways padrão e servidores DNS.
- Facilidade de Administração - Facilita a gestão de redes automatizando a distribuição de endereços IP e configurações de rede.
- Eficiência Operacional - Aumenta a eficiência ao permitir que dispositivos se conectem rapidamente com as configurações corretas.

- Gestão Centralizada - Centraliza a administração das configurações de rede, facilitando manutenção e atualizações.

3 Principais ameaças de segurança

Nesta secção são abordadas as ameaças que podem comprometer a segurança destes serviços.

3.1 Ameaças de Segurança ao DNS

3.1.1 Ataques de Envenenamento de Cache (*Cache Poisoning*):

Este ataque envolve a inserção de informações fraudulentas na cache de um servidor DNS. Quando um servidor é envenenado, ele armazena dados falsos que redirecionam os utilizadores para sites maliciosos ou não intencionais. Isto pode levar ao roubo de informações pessoais e financeiras, comprometendo a segurança de milhares de utilizadores.

3.1.2 Ataques DDoS (*Distributed Denial of Service*):

Ataques DDoS contra servidores DNS são projetados para sobrecarregar os servidores com uma quantidade massiva de requisições. Estes ataques visam esgotar os recursos do servidor, resultando numa indisponibilidade do serviço para os utilizadores legítimos. Um exemplo notável foi o ataque contra a Dyn em 2016, que utilizou uma botnet composta por dispositivos IoT comprometidos. Este ataque afetou grandes plataformas online, como Twitter, Netflix e Reddit, demonstrando o potencial disruptivo desses ataques.

3.1.3 DNS Spoofing:

O *DNS spoofing* envolve a resposta a consultas DNS com informações incorretas ou maliciosas. Isso pode ser realizado interceptando comunicações entre o cliente e o servidor DNS ou configurando um servidor DNS malicioso para responder a consultas de forma fraudulenta. O objetivo é redirecionar os utilizadores para sites controlados pelo atacante, onde podem ser vítimas de *phishing* ou *malware*.

3.2 DHCP

3.2.1 Rogue DHCP Server:

Um Rogue DHCP Server é um servidor DHCP não autorizado que fornece configurações de rede maliciosas aos dispositivos na rede. Isso pode resultar em redirecionamento de tráfego para redes controladas por atacantes, facilitando a interceptação de dados e outros ataques maliciosos. Um exemplo comum é um dispositivo mal configurado que inadvertidamente atua como servidor DHCP, causando problemas de conectividade e expondo a rede a riscos de segurança.

3.2.2 DHCP Starvation Attack

Este tipo de ataque envolve o envio de um grande número de solicitações DHCP falsas para esgotar a *pool* de endereços IP disponíveis no servidor DHCP. Uma vez esgotados os endereços, novos dispositivos não se podem conectar à rede, resultando em uma negação de serviço. Este ataque pode ser utilizado como um precursor para a configuração de um *Rogue DHCP Server*, já que os dispositivos podem então ser forçados a conectar-se ao servidor malicioso.

3.3 DHCP Spoofing:

No DHCP spoofing, um atacante responde a requisições DHCP antes do servidor legítimo, fornecendo informações de configuração incorretas. Isso pode incluir a atribuição de um gateway padrão malicioso, redirecionado todo o tráfego de rede através de um dispositivo controlado pelo atacante. Este método pode ser utilizado para realizar ataques de Man-in-the-Middle (MitM), onde o atacante intercepta e manipula comunicações entre o cliente e o servidor.

4 Exemplos de interrupção de serviço a servidores DNS

4.1 Ataque DDoS aos servidores DNS da plataforma GitHub(2018)

O incidente de ataque DDoS à GitHub em 2018 destacou uma vulnerabilidade significativa nos servidores DNS da plataforma, resultando em interrupções significativas nos serviços oferecidos aos developers e utilizadores do GitHub. Durante o ataque, os servidores DNS do GitHub foram alvo de uma volumosa quantidade de tráfego malicioso, proveniente de uma botnet, com o objetivo de sobrecarregar e tornar inacessíveis os serviços hospedados na plataforma.

4.1.1 Mecanismos de ataque:

- **Ataque DDoS:** Utilização de uma botnet para enviar um volume enorme de solicitações DNS falsas aos servidores do GitHub, com o objetivo de sobrecarregar a capacidade de resposta.
- **Exploração de Vulnerabilidades:** A exploração de vulnerabilidades nos servidores DNS do GitHub permitiu que os atacantes comprometessem a disponibilidade dos serviços, prejudicando milhões de utilizadores globalmente.

4.1.2 Impacto do ataque:

- **Interrupções de Serviço:** Milhões de developers e utilizadores do GitHub enfrentaram dificuldades para aceder e utilizar os serviços da plataforma devido à sobrecarga dos servidores DNS.
- **Prejuízos Financeiros e de Reputação:** O ataque causou danos financeiros e de reputação ao GitHub, além de afetar adversamente a confiança dos utilizadores na segurança dos seus serviços.

4.1.3 Resposta ao Incidente:

- **Mitigação de Ataques:** O GitHub implementou medidas de mitigação para reduzir o impacto do ataque DDoS, fortalecendo as defesas contra futuros incidentes semelhantes.

- **Cooperação com Especialistas em Segurança:** O GitHub colaborou com especialistas em segurança cibernética para identificar as vulnerabilidades exploradas e implementar correções eficazes.

4.2 Incidente de Ataque DDoS à Cloudflare (2020)

Outro incidente de ataque DDoS a servidores DNS é o incidente de ataque à Cloudflare em 2020 que expôs os desafios enfrentados por provedores de serviços de infraestrutura crítica perante ameaças cibernéticas cada vez mais sofisticadas. Durante o ataque, os servidores DNS da Cloudflare foram alvo de uma campanha coordenada de tráfego malicioso, com o objetivo de sobrecarregar os sistemas e comprometer a disponibilidade de serviços essenciais hospedados na plataforma.

4.3 Ataques a servidores DHCP

4.3.1 Ataque DHCP Spoofing

:

Em 2021, um ataque DHCP Spoofing foi relatado em uma rede corporativa, onde um invasor conseguiu enviar pacotes DHCP falsificados para os clientes. Isso resultou na atribuição de configurações de rede erradas, direcionando tráfego sensível para servidores controlados pelo invasor. Este tipo de ataque pode levar a vazamento de dados e interceptação de tráfego.

4.3.2 Ataque DHCP Starvation

:

Em 2020, ocorreu um DHCP Starvation Attack em uma universidade, onde um atacante inundou o servidor DHCP com um grande número de solicitações de atribuição de endereços IP. Isso esgotou a *pool* de endereços IP disponíveis para dispositivos legítimos, impedindo novos dispositivos de se conectar à rede. Este ataque resultou em interrupções de serviço significativas dificultando a administração da rede.

4.3.3 Rogue DHCP Server

:

Em 2019, uma empresa de médio porte foi alvo de um *Rogue DHCP Server*. Um dispositivo comprometido foi configurado como um servidor DHCP não autorizado dentro da rede corporativa. Isso levou à atribuição de configurações de rede incorretas para os clientes, causando confusão na rede e permitindo ao invasor interceptar tráfego sensível. Esse tipo de ataque resultou na violação de dados e comprometeu a integridade da rede.

5 Melhores Práticas e Mecanismos de Segurança

Neste tópico estão expostas as melhores práticas e mecanismos de segurança atuais que ajudem a manter estes serviços sólidos do ponto de vista da segurança.

5.1 DNS

5.1.1 DNSSEC (Domain Name System Security Extensions):

DNSSEC é uma extensão do protocolo DNS que permite a adição de assinaturas digitais às respostas DNS. Isso garante que os dados recebidos são autênticos e não foram alterados. DNSSEC utiliza um sistema de chaves públicas e privadas para assinar os dados DNS, permitindo que os resolvers DNS verifiquem a integridade e a autenticidade das respostas. A implementação do DNSSEC ajuda a mitigar ataques de envenenamento de cache e *spoofing*.

5.1.2 Implementação de Respostas DNS autenticadas

:

A utilização de protocolos como DNS-over-HTTPS (DoH) e DNS-over-TLS (DoT) ajuda a proteger a privacidade e a integridade das consultas DNS. Estes protocolos criptografam as consultas DNS entre o cliente e o resolvedor, impedindo que atacantes interceptem e manipulem as comunicações. Isso é particularmente importante em redes públicas ou não confiáveis, onde as comunicações DNS podem ser facilmente interceptadas.

5.1.3 Monitoramento e Análise de Tráfego DNS

A implementação de sistemas de monitoramento contínuo para detetar padrões anômalos de tráfego pode ajudar a identificar e mitigar ataques DNS. Ferramentas de análise de tráfego podem detetar picos incomuns no volume de consultas ou respostas DNS, indicando um possível ataque DDoS ou outras atividades maliciosas. Além disso, o monitoramento proativo permite a identificação rápida de servidores DNS comprometidos ou mal configurados.

5.2 DHCP

5.2.1 Autenticação e Autorização de Servidores DHCP:

A implementação de mecanismos para verificar a autenticidade dos servidores DHCP antes de permitir que eles forneçam configurações IP é essencial para prevenir ataques de servidores DHCP falsos. Isto pode incluir a utilização de listas de controlo de acesso (ACLs) para restringir quais os dispositivos que podem atuar como servidores DHCP na rede, bem como a implementação de protocolos de autenticação, como o 802.1X.

5.2.2 Isolamento de Tráfego DHCP

A utilização de VLANs (virtual Local Area Networks) como meio de isolamento do tráfego DHCP ajuda na limitação à exposição dos dispositivos não autorizados. Ao segmentar a rede em VLANs separadas, é possível restringir o alcance de um servidor DHCP e mitigar o impacto de um possível ataque. Isto facilita também o controlo e o monitoramento de tráfego DHCP, permitindo uma resposta mais rápida a incidentes de segurança.

5.2.3 DHCP Snooping:

DHCP snooping é uma técnica que permite aos switches de rede inspecionar mensagens DHCP e filtrar respostas de servidores não autorizados. Com DHCP snooping habilitado, o switch pode identificar quais portas estão conectadas a servidores DHCP legítimos e bloquear mensagens DHCP de outras portas. Isso ajuda a prevenir ataques de servidores DHCP falsos e garante que os dispositivos na rede recebam configurações de servidores autorizados.

6 Conclusão

A segurança dos serviços DNS e DHCP é crucial para a estabilidade e a funcionalidade da internet. Através da implementação de práticas e mecanismos de segurança robustos, é possível mitigar os riscos associados às ameaças comuns e garantir a continuidade dos serviços.

Foram então exploradas as principais ameaças de segurança enfrentadas pelos serviços fundamentais da Internet, como o DNS e o DHCP. Depois de uma pesquisa ampla sobre estes serviços e uma análise detalhada, foram identificadas vulnerabilidades específicas, relatando incidentes reais que destacam a importância da segurança nestes protocolos.

A pesquisa revelou que, apesar dos avanços em tecnologias de segurança, os ataques cibernéticos continuam a representar uma ameaça significativa.

Para mitigar esses riscos, a implementação rigorosa de melhores práticas de segurança é essencial. Isso inclui o uso de firewalls, sistemas avançados de detecção e prevenção de intrusões, criptografia robusta, atualizações regulares de software, autenticação multifatorial e monitoramento contínuo.

Neste último trabalho da UC Gestão e Segurança de Redes, é importante destacar a importância de uma abordagem proativa e constante vigilância para proteger estes serviços fundamentais contra estes ataques, pois só assim será possível uma proteção eficaz das infraestruturas críticas da internet contra ameaças em constante evolução.

7 Referências

- https://en.wikipedia.org/wiki/Domain_Name_System
- <https://www.cloudflare.com/learning/dns/what-is-dns/>
- <https://www.auvik.com/franklyit/blog/rogue-dhcp-server/>
- <https://www.rapid7.com/blog/post/2019/02/07/alert-on-rogue-dhcp-servers/>
- <https://www.itprotoday.com/security/detecting-rogue-dhcp-server>
- <https://www.wired.com/story/github-ddos-memcached/>
- <https://blog.cloudflare.com/cloudflare-outage-on-july-17-2020>
- <https://www.cisa.gov/news-events/alerts/2017/11/14/hidden-cobra-north-korean-trojan-volgmer>
- <https://www.sciencedirect.com/science/article/abs/pii/S0045790612001140>
- <https://medium.com/@cybersecuritystephen/unmasking-the-hidden-dangers-how-rogue-dhcp-servers-and-dns-attacks-threaten-your-network-security-6ddffc8c94fa>